API Security Risk Analysis Report

Target API: JSONPlaceholder Test API

Assessment Type: API Security Risk Analysis

Tools Used: Postman, Browser DevTools, JSONPlaceholder API

Prepared By: Sanya Bhatia

Date: 16th May 2026

Executive Summary

An API Security Risk Analysis was conducted on the JSONPlaceholder public test API to identify common API security risks related to authentication, authorization, excessive data exposure, and request handling.

The assessment involved inspecting publicly accessible API endpoints using Postman and Browser DevTools. Several common API security concerns were identified, including unrestricted public access to endpoints, excessive exposure of user information, and lack of visible rate-limiting controls.

Although JSONPlaceholder is intentionally designed as a testing API with fake data, the identified behaviors demonstrate security risks that could become serious vulnerabilities if implemented in real-world production systems.

The overall security posture for a real-world equivalent implementation would be classified as:

🟠 MEDIUM RISK

Assessment Objective

The purpose of this assessment was to:

- Analyze API endpoints for security weaknesses
- Review authentication and authorization mechanisms
- Identify excessive data exposure risks
- Assess request handling and rate-limiting controls
- Provide remediation recommendations

Scope

Item	Details
Target API	JSONPlaceholder
Environment	Public Demo API
Testing Tools	Postman, Browser DevTools
Testing Type	Passive Security Analysis
Focus Areas	Authentication, Authorization, Data Exposure

Methodology

The following methodology was used during the assessment:

1. API Enumeration

Public API endpoints were identified and inspected.

2. Request Analysis

GET and POST requests were analyzed using Postman.

3. Authentication Review

Endpoints were checked for authentication requirements.

4. Authorization Testing

User-specific endpoints were reviewed for access control weaknesses.

5. Data Exposure Analysis

API responses were inspected for unnecessary information disclosure.

6. Risk Classification

Identified issues were classified as Low, Medium, or High risk.

Tools Used

Tool	Purpose
Postman	API request testing
Browser DevTools	Request & response inspection
JSONPlaceholder	Demo API testing

API Endpoints Tested

Endpoint	Method	Purpose
`/users`	GET	Retrieve user data
`/users/1`	GET	Retrieve specific user
`/posts`	GET	Retrieve posts
`/posts`	POST	Test data submission
`/comments`	GET	Retrieve comment data

Finding 1 — Public API Access Without Authentication

Risk Level: 🟠 Medium

Description: The /users endpoint can be accessed publicly without requiring authentication, API keys, or access tokens. The API returns user information directly to unauthenticated users.

Business Impact

In a real-world application, public exposure of user data may:

- Increase phishing risks
- Expose customer information
- Assist attackers in social engineering
- Cause privacy concerns

Endpoint tested:

https://jsonplaceholder.typicode.com/users

Finding1 - Public API Access without Authentication

https://jsonplaceholder.typicode.com/users

Import favorites Learn C and C++ p... Coffeee Android A

Pretty-print


```
{
  "id": 1,
  "name": "Leanne Graham",
  "username": "Bret",
  "email": "Sincere@april.biz",
  "address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
      "lat": "-37.3159",
      "lng": "81.1496"
    }
  },
  "phone": "1-770-736-8031 x56442",
  "website": "hildegard.org",
  "company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural-net",
    "bs": "harness real-time e-markets"
  }
},
{
  "id": 2,
  "name": "Ervin Howell",
  "username": "Antonette",
  "email": "Shanna@melissa.tv",
  "address": {
    "street": "Victor Plains",
    "suite": "Suite 879",
    "city": "Wisokyburgh",
    "zipcode": "90566-7771",
    "geo": {
      "lat": "-43.9509",
      "lng": "-34.4618"
    }
  },
```



```
  },
  "phone": "010-692-6593 x09125",
  "website": "anastasia.net",
  "company": {
    "name": "Deckow-Crist",
    "catchPhrase": "Proactive didactic contingency",
    "bs": "synergize scalable supply-chains"
  }
},
{
  "id": 3,
  "name": "Clementine Bauch",
  "username": "Samantha",
  "email": "Nathan@yesenia.net",
  "address": {
    "street": "Douglas Extension",
    "suite": "Suite 847",
    "city": "McKenziehaven",
    "zipcode": "59590-4157",
    "geo": {
      "lat": "-68.6102",
      "lng": "-47.0653"
    }
  },
  "phone": "1-463-123-4447",
  "website": "ramiro.info",
  "company": {
    "name": "Romaguera-Jacobson",
    "catchPhrase": "Face to face bifurcated interface",
    "bs": "e-enable strategic applications"
  }
},
{
  "id": 4,
  "name": "Patricia Lebsack",
  "username": "Karianne",
  "email": "Julianne.OConner@kory.org",
  "address": {
    "street": "Hoeger Mall",
```


Pretty-print


```
    "address": {
      "street": "Hoeger Mall",
      "suite": "Apt. 692",
      "city": "South Elvis",
      "zipcode": "53919-4257",
      "geo": {
        "lat": "29.4572",
        "lng": "-164.2990"
      }
    },
    "phone": "493-170-9623 x156",
    "website": "kale.biz",
    "company": {
      "name": "Robel-Corkery",
      "catchPhrase": "Multi-tiered zero tolerance productivity",
      "bs": "transition cutting-edge web services"
    }
  },
  {
    "id": 5,
    "name": "Chelsey Dietrich",
    "username": "Kamren",
    "email": "Lucio_Hettinger@annie.ca",
    "address": {
      "street": "Skiles Walks",
      "suite": "Suite 351",
      "city": "Roscoeview",
      "zipcode": "33263",
      "geo": {
        "lat": "-31.8129",
        "lng": "62.5342"
      }
    },
    "phone": "(254)954-1289",
    "website": "demarco.info",
    "company": {
      "name": "Keebler LLC",
      "catchPhrase": "User-centric fault-tolerant solution",
      "bs": "revolutionize end-to-end systems"
    }
```

Pretty-print

```
},
{
  "id": 6,
  "name": "Mrs. Dennis Schulist",
  "username": "Leopoldo_Corkery",
  "email": "Karley_Dach@jasper.info",
  "address": {
    "street": "Norberto Crossing",
    "suite": "Apt. 950",
    "city": "South Christy",
    "zipcode": "23505-1337",
    "geo": {
      "lat": "-71.4197",
      "lng": "71.7478"
    }
  },
  "phone": "1-477-935-8478 x6430",
  "website": "ola.org",
  "company": {
    "name": "Considine-Lockman",
    "catchPhrase": "Synchronised bottom-line interface",
    "bs": "e-enable innovative applications"
  }
},
{
  "id": 7,
  "name": "Kurtis Weissnat",
  "username": "Elwyn.Skiles",
  "email": "Telly.Hoeger@billy.biz",
  "address": {
    "street": "Rex Trail",
    "suite": "Suite 280",
    "city": "Howemouth",
    "zipcode": "58804-1099",
    "geo": {
      "lat": "24.8918",
      "lng": "21.8984"
    }
  },
```

Pretty-print

```
      "lng": "21.8984"
    }
  },
  "phone": "210.067.6132",
  "website": "elvis.io",
  "company": {
    "name": "Johns Group",
    "catchPhrase": "Configurable multimedia task-force",
    "bs": "generate enterprise e-tailers"
  }
},
{
  "id": 8,
  "name": "Nicholas Runolfsdottir V",
  "username": "Maxime_Nienow",
  "email": "Sherwood@rosamond.me",
  "address": {
    "street": "Ellsworth Summit",
    "suite": "Suite 729",
    "city": "Aliyaview",
    "zipcode": "45169",
    "geo": {
      "lat": "-14.3990",
      "lng": "-120.7677"
    }
  },
  "phone": "586.493.6943 x140",
  "website": "jacynthe.com",
  "company": {
    "name": "Abernathy Group",
    "catchPhrase": "Implemented secondary concept",
    "bs": "e-enable extensible e-tailers"
  }
},
{
  "id": 9,
  "name": "Glenna Reichert",
  "username": "Delphine",
  "email": "Chaim_McDermott@dana.io",
  "address": {
```

Pretty-print

```
    "email": "Chaim_McDermott@dana.io",
    "address": {
      "street": "Dayna Park",
      "suite": "Suite 449",
      "city": "Bartholomebury",
      "zipcode": "76495-3109",
      "geo": {
        "lat": "24.6463",
        "lng": "-168.8889"
      }
    },
    "phone": "(775)976-6794 x41206",
    "website": "conrad.com",
    "company": {
      "name": "Yost and Sons",
      "catchPhrase": "Switchable contextually-based project",
      "bs": "aggregate real-time technologies"
    }
  },
  {
    "id": 10,
    "name": "Clementina DuBuque",
    "username": "Moriah.Stanton",
    "email": "Rey.Padberg@karina.biz",
    "address": {
      "street": "Kattie Turnpike",
      "suite": "Suite 198",
      "city": "Lebsackbury",
      "zipcode": "31428-2261",
      "geo": {
        "lat": "-38.2386",
        "lng": "57.2232"
      }
    },
    "phone": "024-648-3804",
    "website": "ambrose.net",
    "company": {
      "name": "Hoeger LLC",
      "catchPhrase": "Centralized empowering task-force",
      "bs": "target end-to-end models"
```


Remediation

- Require authentication for sensitive endpoints
- Use JWT, OAuth2, or API keys
- Restrict public data exposure

Finding 2 — Excessive Data Exposure

Risk Level: 🟠 Medium

Description: The API response exposes multiple user attributes including:

- Name
- Username
- Email
- Address
- Phone number
- Website
- Company details

More information is exposed than necessary for basic functionality.

Business Impact

- Excessive information disclosure may:
- Assist phishing attacks
- Increase social engineering risks
- Expose sensitive business information

Evidence - Sample fields observed

JSON

```
{
  "email": "Sincere@april.biz",
  "phone": "1-770-736-8031",
  "company": {
    "name": "Romaguera-Crona"
  }
}
```

Remediation

- Return only required fields
- Apply least-privilege data exposure
- Minimize sensitive information in API responses

Findings 2 - Excessive Data Exposure


```
{
  "id": 1,
  "name": "Leanne Graham",
  "username": "Bret",
  "email": "Sincere@april.biz",
  "address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
      "lat": "-37.3159",
      "lng": "81.1496"
    }
  },
  "phone": "1-770-736-8031 x56442",
  "website": "hildegard.org",
  "company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural-net",
    "bs": "harness real-time e-markets"
  }
},
```

```
},
{
  "id": 2,
  "name": "Ervin Howell",
  "username": "Antonette",
  "email": "Shanna@melissa.tv",
  "address": {
    "street": "Victor Plains",
    "suite": "Suite 879",
    "city": "Wisokyburgh",
    "zipcode": "90566-7771",
    "geo": {
      "lat": "-43.9509",
      "lng": "-34.4618"
    }
  },
  "phone": "010-692-6593 x09125",
  "website": "anastasia.net",
  "company": {
    "name": "Deckow-Crist",
    "catchPhrase": "Proactive didactic contingency",
    "bs": "synergize scalable supply-chains"
  }
},
```

Finding 3 — ID-Based User Access

Risk Level: 🟠 Medium

Description: Changing the numeric ID in the endpoint URL provides access to different user records.

Example:

/users/1

/users/2

/users/3

No visible authorization controls were observed during testing.

Business Impact

In production environments, weak authorization may allow:

- Unauthorized access to user accounts
- Exposure of private information
- Broken access control vulnerabilities

Evidence

Endpoint tested:

https://jsonplaceholder.typicode.com/users/1

Finding 3 - ID Based Access

https://jsonplaceholder.typicode.com/users/1

Import favorites | Learn C and C++ p... | Coffeee Android A... | Inbox

Pretty-print


```
{
  "id": 1,
  "name": "Leanne Graham",
  "username": "Bret",
  "email": "Sincere@april.biz",
  "address": {
    "street": "Kulas Light",
    "suite": "Apt. 556",
    "city": "Gwenborough",
    "zipcode": "92998-3874",
    "geo": {
      "lat": "-37.3159",
      "lng": "81.1496"
    }
  },
  "phone": "1-770-736-8031 x56442",
  "website": "hildegard.org",
  "company": {
    "name": "Romaguera-Crona",
    "catchPhrase": "Multi-layered client-server neural-net",
    "bs": "harness real-time e-markets"
  }
}
```


Remediation

- Implement authorization validation
- Ensure users access only permitted resources
- Enforce role-based access control (RBAC)

https://jsonplaceholder.typicode.com/users/2

Import favorites | Learn C and C++ p... | Coffeee Android A... | Inb

Pretty-print


```
{
  "id": 2,
  "name": "Ervin Howell",
  "username": "Antonette",
  "email": "Shanna@melissa.tv",
  "address": {
    "street": "Victor Plains",
    "suite": "Suite 879",
    "city": "Wisokyburgh",
    "zipcode": "90566-7771",
    "geo": {
      "lat": "-43.9509",
      "lng": "-34.4618"
    }
  },
  "phone": "010-692-6593 x09125",
  "website": "anastasia.net",
  "company": {
    "name": "Deckow-Crist",
    "catchPhrase": "Proactive didactic contingency",
    "bs": "synergize scalable supply-chains"
  }
}
```

Finding 4 — POST Requests Accepted Without Authentication

Risk Level

🟠 **Medium**

Description: The API accepted POST requests without requiring authentication. A test POST request successfully returned a response.

Business Impact

In real systems, unauthenticated write requests may:

- Allow fake data creation
- Enable spam or abuse
- Result in unauthorized modifications

Remediation

- Require authentication for write operations
- Validate user permissions
- Restrict POST, PUT, PATCH, and DELETE requests

Finding 5 — Missing Visible Rate Limiting

Risk Level: 🟡 Low–Medium

Description: During manual testing, no visible rate-limiting controls or warning responses were observed.

Business Impact

Without rate limiting, APIs may become vulnerable to:

- Abuse
- Automated scraping
- Brute-force attempts
- Denial-of-service attacks

Evidence

Multiple requests were accepted without visible throttling.

Remediation

- Implement API rate limiting
- Use throttling mechanisms
- Monitor abnormal traffic patterns

Risk Summary

Finding	Severity
Missing Authentication	Medium
Excessive Data Exposure	Medium
Weak Authorization Risk	Medium
Unauthenticated POST Requests	Medium
Missing Visible Rate Limiting	Low–Medium

Overall Risk Rating

🟠 MEDIUM RISK

The analyzed API demonstrates several common API security weaknesses that could become serious vulnerabilities if implemented in a production environment.

Recommendations

Immediate Improvements

- ✓ Require authentication for sensitive endpoints
- ✓ Reduce unnecessary data exposure
- ✓ Implement authorization checks
- ✓ Restrict write operations
- ✓ Monitor API usage patterns

Long-Term Security Improvements

- ✓ Implement OAuth2 or JWT authentication
- ✓ Use role-based access control (RBAC)
- ✓ Enable API rate limiting
- ✓ Validate and sanitize input data
- ✓ Maintain API security testing procedures

Conclusion

The API Security Risk Analysis identified several common API security concerns related to authentication, authorization, and data exposure.

Although the target API is intentionally designed for testing purposes, the observed behaviors demonstrate how insecure API implementations may expose organizations to data leakage, abuse, and unauthorized access risks.

Proper authentication, authorization, rate limiting, and data minimization are essential to maintaining secure API environments.